

Security

CRM/ERP Platform Documentation

Security

Authentication Security

- Passwords are hashed with **bcryptjs** (10 salt rounds) — no plain-text passwords stored anywhere
 - JWT access tokens expire in **24 hours**; refresh tokens in **7 days**
 - Refresh tokens are stored in `User.refreshToken` (hashed) and invalidated on logout
 - `mustChangePassword` flag forces password change before any other action
 - Account lockout: `LOCKED` status can be set manually by SUPER_ADMIN (no automatic brute-force lockout is implemented)
-

CORS

Configured in `backend/src/main.ts` :

```
app.enableCors({
  origin: (origin, callback) => {
    const allowed = process.env.FRONTEND_URL?.split(',') ?? [];
    if (!origin || allowed.includes('*') || allowed.includes(origin)) {
      callback(null, true);
    } else {
      callback(new Error('Not allowed by CORS'));
    }
  },
  credentials: true,
});
```

- Set `FRONTEND_URL` to a comma-separated list of allowed origins in production
 - Never use `*` with `credentials: true` in production
-

Rate Limiting

ThrottlerModule is applied globally:

- **100 requests** per **60 seconds** per IP

To adjust:

```
ThrottlerModule.forRoot([ { ttl: 60000, limit: 100 } ])
```

Public form submission endpoints (`/public/forms/*`) are subject to the same limit — for high-volume forms, increase the limit or implement token-bucket per form.

Input Validation

ValidationPipe with `whitelist: true` strips any properties not declared in DTOs. This prevents mass assignment attacks.

```
app.useGlobalPipes(new ValidationPipe({
  whitelist: true,
  forbidNonWhitelisted: false,
  transform: true,
}));
```

SQL Injection

Prisma ORM uses parameterized queries throughout. Direct `$executeRaw` calls (used in a few places for Prisma type limitations) always use tagged template literals which are parameterized, not string concatenation.

File Upload Security

- Files are served from random-token URLs (no directory listing)
 - MIME type is validated by multer
 - File size limited to 10 MB
 - Uploaded files are not executable — served as static assets, not executed
-

API Keys

API keys are:

- Stored as `bcrypt(key)` in the database — the plain key is never stored
 - Prefixed for identification (e.g., `crm_live_...`) without revealing the full key
 - Revocable instantly by setting `isActive: false`
 - Support expiry dates
-

Audit Logging

All significant actions create an `AuditLog` entry:

```
{
  "userId": "...",
  "organizationId": "...",
  "action": "record.updated",
  "entityType": "Record",
  "entityId": "...",
  "metadata": { "changed": { "status": ["draft", "active"] } },
  "ipAddress": "...",
  "userAgent": "..."
}
```

Query via `GET /audit` (ADMIN+). Logs are append-only — no delete endpoint.

Multi-tenancy Isolation

Every database query includes `organizationId` in the WHERE clause. A user from Organization A can never access Organization B's data — even with a valid JWT — because the JWT's `organizationId` restricts all queries.

SUPER_ADMIN users can query across organizations via `GET /organizations`.

Secret Management

- Never commit `.env` files to git (both are in `.gitignore`)
 - In production, use your hosting provider's secret manager (Railway env vars, Netlify env vars, AWS Secrets Manager)
 - Rotate `JWT_SECRET` periodically — this invalidates all existing sessions
 - The `ANTHROPIC_API_KEY` carries billing liability; restrict it to the backend process only
-

Security Headers

NestJS/Express doesn't set security headers by default. For production, add **Helmet**:

```
cd backend && npm install helmet
```

```
// main.ts
import helmet from 'helmet';
app.use(helmet());
```

This adds `X-Frame-Options`, `X-Content-Type-Options`, `HSTS`, etc.

Known Limitations

- No automatic brute-force protection on login (only manual account locking)
- File URLs are security-by-obscurity (long random tokens, no signed URLs with expiry)

- WebSocket connections use the same JWT but there's no per-message auth re-validation
- No CSP header configured by default

These are acceptable for an internal deployment but should be addressed for internet-facing production use.